Name: Vaishaal Rajha | Roll No: 231901502

Experiment 9: Compliance Assessments — Test of Design and Test of Operational Effectiveness

Objective

To run a compliance assessment in Eramba that evaluates compliance requirements through both a Test of Design (ToD) and a Test of Operational Effectiveness (ToOE), and to connect these requirements with the relevant policies, controls, and risks.

Steps Followed

1. Signed in to the Eramba GRC platform.
2. Opened Compliance Management and then Compliance Packages.
3. Created a new package titled Exp 9 Information Security Compliance Assessment.
4. Added requirements to the package via the Compliance Package Items section.
5. Configured 20 compliance items spanning access control, data protection, incident management, vulnerability management, backup, and business continuity.
6. Opened Compliance Management and then Compliance Analysis.
7. Selected the newly created package to view its requirements.
8. Opened the DP-02 (Data Retention) item for detailed review.
9. Set its Compliance Strategy to Compliant and assigned an owner.
10. Linked applicable internal controls, policies, and business risks to the item.
11. Documented the Test of Design (ToD) to confirm the policy/process is properly defined and documented.
12. Documented the Test of Operational Effectiveness (ToOE) to confirm the control is actively operating with supporting evidence.
13. Saved the assessment and reviewed the resulting compliance status.

Compliance Package Items (Extract)

Item ID	Item Name	Compliance Strategy
DP-02	Data Retention	Compliant
BC-01	Business Continuity Plan	-
PS-01	Physical Access Control	-
TP-02	Third-Party Security Clauses	-
TP-01	Supplier Security Assessment	-
IM-03	Incident Response Testing	-
IM-02	Incident Reporting	-
SA-01	Security Awareness Training	-
BR-02	Backup Restoration Testing	-

Linked Records for DP-02 — Data Retention

- Internal Controls: Backup and Recovery, Firewall Management
- Policies: Access Control Policy, Password Policy
- Business Risks: Data Breach, Unauthorized Access
- Liabilities: Employee Data

Outcome

A compliance package with 20 requirements was created and assessed. The chosen requirement (DP-02) was assigned a compliance strategy, an owner, and linked controls, policies, and risks, with ToD and ToOE documentation confirming both the design and the actual operation of the control.